

Applicability Compliance V2

What will not be applicable

- Physical controls
- Wireless
- Policies and Documents Supported

Not Applicable

1.1 : Policy and RACI

1.2.1 : rules set

1.2.2 : approved

1.2.7 : review rule set 6 months

1.3.3 : wireless

2.1 : Policy and RACI

2.3 : Wireless securely

3.1 : Policy and RACI

3.7.2 : Policy KMS

3.7.3 : Policy Procedure KMS

3.7.8 : Policy Custodian

3.7.9 : Third party must know the policy of the organization KMS

4.1 : Policy and RACI

5.1 : Policy and RACI

5.2.3 : document those component which don't comply with anti-malware

6.1 : Policy and RACI

6.2.1 : document CI/CD

6.2.2 : Training for secure code

6.3 : secure code

6.4.1 : continues detect and prevent web-based attacks

6.5.1 : Policy and procedure of coding

6.5.2 : all changes must apply to new or changed systems

7.1 : Policy and RACI

7.2 : People privilege and restriction

8.1 : Policy and RACI

8.2.3 : no remote unique ID for vendors

8.2.7 : time a specific duration for vendor to remote and have done their tasks

8.3.8 : authentication procedure for all users

8.3.11 : Authentication tokens, smart cards, and certificates must be assigned to one user only and must not be shared

8.4.3 : MFA for remote access to CDE

10.6.3 : have restriction on role basis need to know and change management

10.7 : no patching or unified system for system failure

10.1 : Policy and RACI

10.3.3 : store somewhere difficult to modify from outside technology and components

11.1 : Policy and RACI

Applicable

Requirement 1 : Network

1.2.3 : Diagram

1.2.4 : Dataflows

1.2.5 : Services and port are defined business needs, disabled by default

1.2.6 : Not use insecure security feature since it lead to risk

1.3.1 : Inbound deny by default, allow on specific

1.3.2 : Outbound deny by default, allow on specific

1.4.1 : Implemented between trusted and untrust network

1.4.2 : Authorized com between trusted and untrusted with stateful response firewall, other denied by default

1.4.3 : Anti spoofing

1.4.4 : CDE can't reached directly from untrusted network

1.4.5 : Disclosure to those responsible and restricted to business need to know

1.5.1 : Device which can be accessed to both CDE and internet must have security controls to prevent tampering or data exfiltration

Requirement 2 : Apply Secure Configurations to All System Components

2.2.1 : formal secure configuration baseline for all system (refers to CIS, NIST, ISO)

2.2.2 : Do not use default setting of vendor, Must change

2.2.3 : Do not use 1 server as all in one (DB, APP, UTIL, WEB)

2.2.4 : disable services by default, allow on specific

2.2.5 : If there's insecure services, business justification is needed and compensating controls

2.2.6 : securely configure system settings according to your hardening standard

2.2.7 : Remote access must be encrypted using strong cryptography

Requirement 3 : Protect Stored Account Data

3.2.1 : data retention, CHD matrix, secure delete data, check every 3 months

3.3.1 : SAD (T2, CVV, PIN) shall never be stored and only used for authentication and then disposal

3.3.2 & 3.3.3 : SAD must be encrypted all time

3.4.1 : Masking and leave only last 4

3.4.2 : prevent users from copy, download PAN remotely unless authorized

3.5.1 : PAN must be unreadable by (hashing, truncation, tokenization and encryption) when stored while have KMS and Disk level encryption and separated (3.5.1.1 & 3.5.1.2 & 3.5.1.3)

3.6.1 : secure KEK

3.7.1 : Use KMS

3.7.4 : key rotation

3.7.5 : Key destruction

3.7.6 : Split knowledge

3.7.7 : key must be protected from being replaced or tampered with by unauthorized sources

Requirement 4 : Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

4.2.1 : encrypt PAN over transmit, TLS, disable weak protocol and with up to date cryptography

4.2.2 : use secured end-user messaging app whenever send PAN

Requirement 5

5.2.1 : deploy anti-malware to all component

5.2.2 : solution must (detect all malware, remove, blocks, contains)

5.3.1 : keep anti-malware up to date

5.3.2 : scan periodic and active or realtime...

5.3.3 : scan disk and such...

5.3.4 : enable audit log in anti-malware

5.3.5 : anti-malware cannot be disabled or altered by users

5.4.1 : anti-phishing deployment

Requirement 6 : Develop and Maintain Secure Systems and Software

6.2.3 : review code before publishing

6.2.4 : Build software securely to prevent common attacks and vulnerabilities from reaching production

6.4.1 : testing in front of DMZ public facing

6.4.3 : Control and protect all JavaScript loaded on payment pages

6.5.3 : pre-prod and prod must be separated

6.5.4 : separate between pre-prod and prod to track accountability

6.5.5 : never use live PAN on pre-prod or anything insecure

6.5.6 : testing PAN data must be delete before prod

Requirement 7 : Restrict Access to System Components and Cardholder Data by Business Need to Know

7.3.1 : have access control for need to know to do basis

7.3.2 : based on role and position

7.3.3 : access control is set to deny by default

Requirement 8 : Identify Users and Authenticate Access to System Components

8.2.1 : users have unique ID

- 8.2.2 : not using share ID
- 8.2.4 : add, delete, modification of user ID for authorization
- 8.2.5 : access for terminated users is immediately revoked
- 8.2.6 : inactive user account removed or disabled within 90 days
- 8.2.8 : user timeout when idle more than 15 minutes and need to re-authenticate, log off an hour
- 8.3.1 : something they know, have and are rule
- 8.3.2 : strong cryptography
- 8.3.3 : user must be verified before modify authentication factor
- 8.3.4 : lock out for not more than 10 attempts, lock for minimum of 30 mins or when user confirmed
- 8.3.5 : do not use default password after reset
- 8.3.6 : password must be strong (8 if 12 not support otherwise 12 as minimum and both numeric and alphabetic)
- 8.3.7 : cannot use the same passwords which same as last 4 times
- 8.3.9 : single sign password must be changed at least once in 90 days or accept risk
- 8.3.10 : single sign password in CDE must be changed periodically
- 8.4.1 : MFA for non-console privilege access
- 8.4.2 : MFA for all non-console in CDE
- 8.5.1 : MFA must be secure, mandatory, and use at least two different authentication factors
- 8.6.1 : System and application accounts should not allow human logins. If interactive login is required, it must be temporary, approved, justified, and fully traceable to an individual.
- 8.6.2 : password should not be hardcoded into system which used for interactive
- 8.6.3 : change password periodically

Requirement 9 : Restrict Physical Access to Cardholder Data

None

Requirement 10 : Log and Monitor All Access to System Components and Cardholder Data

- 10.2.1 : enable all logs
- 10.3.1 : need to know basis based on role to view the logs
- 10.3.2 : protect from tempering on logs
- 10.3.4 : FIM to prevent unauthorized modification
- 10.4.1 : review log daily
- 10.4.2 : review all other system components log periodically
- 10.4.3 : exceptions and anomalies must be reviewed and addressed
- 10.5.1 : retain logs history 12 months and 3 months prior must be available
- 10.6.1 : deploy NTP
- 10.6.2 : sync time across all component

Requirement 11 : Test Security of Systems and Networks Regularly

- 11.3.1 : perform internal vulnerability scans quarterly
 - 11.3.1.2 : implement authenticated internal scans
 - 11.3.1.3 : run internal scans after significant changes
 - 11.3.2.1 : run external scans after significant changes
- 11.4.5 : validate scope and segmentation annually
- 11.4.6 : validate scope and segmentation every 6 months for service providers
- 11.6.1 : deploy tamper detection for payment page scripts

Requirement 12 : Support Information Security with Organizational Policies and Programs

12.3.3 : maintain inventory of approved cryptographic algorithms and protocols

12.5.1 : maintain accurate inventory of all system components

12.10.1 : document and implement incident response plan

12.10.2 : test incident response plan